

BEFORE Placeholder

AFTER

Identity & Access Management (IAM) Control Baseline (Tiered)

Document classification: Internal

Baseline owner: Security Engineering/Architecture

Version: 0.1

Effective date: _____

Review cadence: Annually

1. Purpose

Define minimum IAM controls for third parties, including SSO, MFA, RBAC, provisioning/deprovisioning, privileged access, and validation steps to prove controls are implemented.

2. Scope

Applies to suppliers that:

- provide user access to a SaaS/admin portal, and/or
- require any administrative or privileged access, and/or
- integrate via API/service accounts, and/or
- support critical services or process sensitive data.

3. Control statements (tiered)

3.1 Tier Critical (Tier 1) — MUST controls

Critical suppliers MUST:

1. **SSO for standard users** where supported (SAML/OIDC).
 - If not supported, require exception plus compensating controls.
2. **MFA for all administrative access** (supplier-side and/or via IdP conditional access).
3. **Least privilege RBAC:**
 - roles defined and mapped to job functions
 - admin privileges restricted to named users
 - separation of read vs write/change privileges where the platform supports it
4. **No shared accounts** for day-to-day use (users must be uniquely identifiable).
5. **Controlled privileged support access:**
 - privileged access is approved, auditable, and time-bounded where feasible
 - break-glass accounts are controlled and monitored (if required)
6. **Access lifecycle controls:**
 - joiner/mover/leaver process documented
 - prompt deprovisioning on leavers and role changes
7. **Auditability:**
 - authentication events and admin role changes are logged and retrievable (see Logging baseline).

Critical suppliers SHOULD:

- support SCIM (or equivalent) for automated provisioning
- support step-up authentication for high-risk actions
- support session logging for privileged support access where feasible

3.2 Tier Important (Tier 2) — MUST controls

Important suppliers MUST:

- enforce MFA for administrative access
- support RBAC/least privilege and restrict admin roles to named users
- provide a joiner/mover/leaver process and timely deprovisioning

- avoid shared accounts (or justify and mitigate)

Important suppliers SHOULD:

- support SSO for standard users where supported
- support SCIM (or documented provisioning process)

3.3 Tier Low (Tier 3) — proportionate controls

Low suppliers SHOULD:

- enable MFA for admin access where supported
- provide role-based access where supported
- support timely access removal on offboarding

4. Baseline requirements by control area

4.1 Authentication (SSO/MFA)

MUST:

- Prefer organisation-controlled authentication via SSO where supported.
- Enforce MFA for admin access at minimum.
- Document any local account usage and restrict it to necessary cases.

SHOULD:

- Apply conditional access (device/geo/risk-based) for Critical suppliers where feasible.

4.2 Authorisation (RBAC / least privilege)

MUST:

- Maintain a role catalogue for the supplier service (minimum roles required).
- Map roles to IdP groups where possible (group-driven access).
- Minimise global/tenant admin count; document list of admin holders by role title.

SHOULD:

- Use separate admin roles (security admin/billing admin) where supported.
- Use read-only roles for assurance/audit use cases.

4.3 Provisioning and deprovisioning (JML)

MUST:

- Define the access request and approval process.
- Ensure deprovisioning occurs promptly when:
 - a user leaves the organisation
 - a user changes role and no longer requires access
 - supplier contract ends/offboarding starts

SHOULD:

- Implement SCIM provisioning where supported.
- Schedule periodic access recertification:
 - Critical: quarterly or semi-annual
 - Important: annual
 - Low: annual or trigger-based

4.4 Privileged access and break-glass

MUST (Critical; where privileged/admin access exists):

- Document privileged access paths (who, how, when).
- Require approval to grant privileged roles.
- Separate break-glass access from normal admin usage.
- Store break-glass credentials in an approved secure store and limit holders.

SHOULD:

- Use brokered access (PAM/JIT) and session capture where feasible.

- Alert on new admin assignments and break-glass use.

4.5 Service accounts / integration identities

MUST:

- Use dedicated non-human identities for integrations (no personal accounts).
- Restrict who can create/modify integration identities.
- Apply least privilege scopes and document them.

SHOULD:

- Separate identities for prod/non-prod and for read/write integrations.
- Rotate credentials on a schedule and on any suspected compromise.

5. Validation steps (how to prove it)

For each supplier, capture evidence and complete checks.

5.1 SSO validation

- ☐ SSO supported and implemented (SAML/OIDC) OR exception recorded
- ☐ Group-driven access configured (IdP groups mapped to roles)
- ☐ Local accounts disabled for standard users where possible

Evidence location:

5.2 MFA validation

- ☐ MFA enforced for all admin access (supplier-side or IdP policy)
- ☐ Admin accounts tested (login requires MFA)

Evidence location:

5.3 RBAC validation

- ☐ Role catalogue documented (or supplier roles documented)
- ☐ Admin roles restricted to named users; list captured
- ☐ Least privilege review completed (no broad roles by default)

Evidence location:

5.4 JML / deprovisioning validation

- ☐ Access request/approval process documented
- ☐ Deprovisioning test completed (sample leaver removed) OR evidence from process
- ☐ Access recertification cadence defined and scheduled

Evidence location:

5.5 Privileged/break-glass validation (if applicable)

- ☐ Break-glass approach documented; storage and holders defined
- ☐ Break-glass use is logged/alerted (where supported)
- ☐ Privileged support access controls documented (approval, time bounds, logging)

Evidence location:

5.6 Integration identity validation (if applicable)

- ☐ Dedicated integration identity used (non-human)
- ☐ Least-privilege scopes documented and reviewed
- ☐ Secrets stored in approved vault/store; rotation defined

Evidence location:

6. Exceptions

If any Tier Critical MUST requirement cannot be met:

- raise a policy exception with compensating controls, expiry date, and remediation plan.

7. Sign-off (per supplier)

Supplier: _____ Service: _____ Tier: ☐ Critical ☐
Important ☐ Low

Security Engineering/Architecture (role title): _____ Date: _____ IT/Platform Owner
(role title): _____ Date: _____ Business Service Owner (role title):
_____ Date: _____ DPO/Privacy Officer (if personal data):
_____ Date: _____